

Sicurezza dell'Infrastruttura AWS in una Startup fintech: Sfide, Best Practices e Implementazione di un Modello di Sicurezza Resiliente Low Cost

Andrea Ferraboli (Matricola 09985A)

Relatore: Prof. Claudio Agostino Ardagna

Correlatori: Lorenzo Perotta,
Andrea Pasini, Simone Cortese

Il settore fintech (Financial Technology) è caratterizzato da una crescita esponenziale, guidata dall'adozione di tecnologie cloud come Amazon Web Services (AWS) per erogare servizi finanziari innovativi. Le startup che operano in questo ecosistema gestiscono dati finanziari e personali estremamente sensibili, posizionandosi all'intersezione tra l'agilità tecnologica e i rigorosi requisiti di sicurezza e conformità normativa del mondo finanziario. Questa tesi analizza il contesto di una startup fintech italiana, la cui infrastruttura è interamente basata su AWS, per affrontare le sfide di sicurezza tipiche di queste realtà. La sfida principale per una startup fintech risiede nel bilanciare la necessità di uno sviluppo rapido e di una rapida immissione sul mercato (*time-to-market*) con l'imperativo di garantire un livello di sicurezza robusto e una piena conformità normativa (es. GDPR, PSD2, DORA). Queste realtà si trovano spesso a operare con risorse finanziarie e umane limitate, il che può portare a sottovalutare la sicurezza, accumulando un "debito tecnico" che ne espone l'infrastruttura a rischi significativi. L'uso estensivo di servizi cloud, se non correttamente configurato, amplifica la superficie d'attacco, rendendo la startup un bersaglio privilegiato per attacchi informatici mirati a furti di dati, frodi e interruzioni di servizio.

Obiettivo di questa tesi è stato progettare, implementare e validare un framework di sicurezza olistico, resiliente e a basso costo, specificamente concepito per le esigenze e i vincoli di una startup fintech. Il modello si fonda sui principi di Zero Trust, Difesa in Profondità e Privacy by Design. L'implementazione pratica si è articolata in tre interventi strategici principali:

- *Ristrutturazione della Gestione di Identità e Accessi (IAM)*: È stato revisionato l'intero sistema IAM, eliminando l'uso improprio dell'account root e dei permessi amministrativi permanenti. È stato introdotto un modello granulare basato su ruoli temporanei con privilegi minimi (*least privilege*), l'uso obbligatorio dell'autenticazione a più fattori (MFA) e meccanismi di controllo preventivo come Permission Boundaries e Service Control Policies (SCP) per ridurre drasticamente il potenziale raggio d'esplosione (*blast radius*) in caso di compromissione.
- *Progettazione di un'Architettura di Rete Sicura*: È stata implementata una rigorosa segmentazione della rete tramite Amazon VPC, con subnet pubbliche e private distribuite su più Availability Zones per garantire alta disponibilità. Controlli di traffico multilivello (Security Groups e Network ACLs), hardening delle istanze EC2

secondo i benchmark CIS, crittografia end-to-end dei dati e adozione di Infrastructure as Code (IaC) con Terraform hanno permesso di creare un ambiente isolato, coerente e automatizzato.

- *Implementazione di un Sistema di Rilevamento Proattivo (Honeypot)*: È stato spiegato e validato un honeypot a media interazione (T-Pot CE) in un ambiente AWS isolato. Questo strumento, integrato con un sensore personalizzato per API fintech, permette di raccogliere *threat intelligence* specifica e di alta qualità, identificando Tattiche, Tecniche e Procedure (TTPs) degli attaccanti con un costo operativo minimo e un ritorno sull'investimento (ROI) strategico estremamente elevato.

Il principale contributo di questo lavoro è la dimostrazione pratica che anche una startup con risorse limitate può e deve adottare una postura di sicurezza avanzata, trasformando la cybersecurity da un centro di costo a un vantaggio competitivo. La tesi fornisce un modello replicabile e pragmatico che integra soluzioni tecniche, analisi dei costi e strategie di conformità, dimostrando come i principi di sicurezza moderni possano essere tradotti in controlli efficaci nell'ambiente AWS.

Il lavoro di tesi delinea un percorso di maturazione continua della sicurezza. Le direzioni future includono la transizione da un'architettura monolitica a una basata su microservizi e container, per una segmentazione ancora più granulare. Altre evoluzioni strategiche comprendono l'adozione di un'architettura multi-region per il disaster recovery, l'integrazione di tutte le fonti di log in una piattaforma SIEM (Security Information and Event Management) per la correlazione avanzata degli eventi e l'automazione della risposta (SOAR). Infine, il potenziamento degli honeypot con sensori sempre più sofisticati e l'adozione di pratiche di Chaos Engineering permetteranno di testare proattivamente la resilienza del sistema, mantenendo la postura di sicurezza allineata all'evoluzione delle minacce e della normativa.